
Primer Reporte de Métricas y Auditoría de Seguridad

Rutsubo — agente de código local-first

Corte 1 de 2 · Lighthouse + OWASP ZAP · evidencia reproducible

Materia	Tecnologías para el Desarrollo de Aplicaciones
Docente	Mtro. Ali Santiago López Zunún
Autor	Ramsés Alejandro Camas Nájera
Programa	MCIT — Sistemas Inteligentes
Periodo	2.º cuatrimestre
Corte	1 de 2
Fecha	13 de julio de 2026

1. Resumen ejecutivo

Este corte documenta la primera medición de rendimiento y auditoría de seguridad de Rutsubo con evidencia reproducible. Se auditaron las **tres superficies HTTP** del sistema conforme a los requisitos no funcionales: la superficie pública estática (Astro) con **Lighthouse** (RNF-02, ADR-002) y las dos APIs —daemon y relay— con **OWASP ZAP** (RNF-09).

Rendimiento (Lighthouse). Las cuatro combinaciones página × perfil (Inicio y Login, en móvil y escritorio) obtienen **Performance 100, Accessibility 100, SEO 100 y Best Practices 96**, con First Contentful Paint entre 165 y 620 ms. El presupuesto RNF-02 (FCP < 1 500 ms) se **cumple con holgura** en las cuatro. Un único hallazgo (un 404 de favicon.ico) explica el 96 de Best Practices.

Seguridad (ZAP). Cero hallazgos de riesgo Alto; cero fallos (FAIL). El **daemon no presentó ninguna alerta** sobre 11 endpoints autenticados: el endurecimiento de cabeceras de la fase API se sostuvo. El relay concentra los **2 hallazgos** del corte: una configuración CORS permisiva (riesgo Medio) y la ausencia de la cabecera X-Content-Type-Options (riesgo Bajo).

Correcciones. Se comprometen **3 correcciones** para el corte 2 (una de Lighthouse, dos del relay); **3 hallazgos** se descartan con justificación técnica y **1** se acepta temporalmente con su disparador. La corrección en caliente prevista para fugas de información (sección 4.3 de la orden) **no fue necesaria**: los cuerpos de error de ambas APIs son sobres ErrorEnvelope estructurados, sin trazas de pila.

2. Metodología

2.1 Herramientas y entorno

Componente	Versión / detalle
Lighthouse (CLI)	13.4.0 (npm)
Navegador	Google Chrome for Testing 149.0.7827.55 (headless)
OWASP ZAP	2.17.0 (imagen zaproxy/zap-stable)
Docker	29.1.3
Sistema	Ubuntu 24.04.3 LTS · WSL2 (kernel 6.6.87)

2.2 Qué mide cada herramienta y por qué

La medición de rendimiento se hace sobre la **superficie pública Astro** —inicio y autenticación— por diseño: es la superficie renderizada de forma estática (ADR-002, *renderizado híbrido*) y la que fija el presupuesto de carga de RNF-02. La aplicación (SPA con render en cliente) no produce *scores* de documento comparables y se reporta aparte solo como nota metodológica. La auditoría de seguridad cubre las dos superficies HTTP expuestas —daemon (127.0.0.1:7431) y relay (127.0.0.1:8443)— tal como exige RNF-09.

2.3 Condiciones de medición (integridad del dato)

Todos los números provienen de ejecuciones reales de esta sesión; los artefactos crudos (JSON) se conservan en docs/audits/corte1/ con su hash SHA-256 (anexo). Condiciones:

- Lighthouse se corre contra el **build de producción** (astro build) servido de forma estática, nunca el servidor de desarrollo.
- **3 corridas** por combinación; se reporta la **mediana** del *score* de Performance (Lighthouse tiene varianza). Las tres corridas de cada combinación coincidieron.

- ZAP se ejecuta como **proxy de escaneo pasivo** sobre los endpoints enumerados de los contratos C-1/C-2. En una API JSON sin raíz navegable el *spider* clásico no descubre rutas; conducir peticiones reales a través del proxy audita las respuestas efectivas (200 autenticadas, 401, 404). El daemon se auditó **con el Bearer local**; sus endpoints protegidos respondieron 200. Las instancias auditadas son **efímeras y desechables** (data-dir temporal y *workspace* de prueba con archivos dummy), nunca trabajo real.

2.4 Comandos ejecutados

Reproducibles sobre el mismo build y las mismas instancias efímeras.

Superficie pública (build de producción servido estático):

```
npm run build (astro) → python3 -m http.server 4321 (dist/)
```

Lighthouse — 4 combinaciones × 3 corridas (mediana):

```
CHROME_PATH=<chromium> lighthouse
http://127.0.0.1:4321/{,login/} [--preset=desktop]
--output=json,html --chrome-flags="--headless=new ..."
```

OWASP ZAP — escaneo pasivo por proxy (contenedor zaproxy/zap-stable):

```
docker run -d -p 8090:8090 zaproxy/zap-stable zap.sh -daemon -port 8090
-config api.disablekey=true
curl -x http://127.0.0.1:8090 -H "Authorization: Bearer <token>"
http://host.docker.internal:7431/v1/{health,sessions,approvals,...}
curl "http://127.0.0.1:8090/OTHER/core/other/jsonreport/" -o zap-daemon.json
```

Nota de red: en Docker Desktop sobre WSL2 el contenedor alcanza el host por `host.docker.internal` (no por `--network=host`); es el mismo daemon/relay de 127.0.0.1, comprobado por respuesta idéntica.

2.5 WebPageTest

La rúbrica lo admite como alternativa a Lighthouse. No se usa: exige una URL pública y este corte se mide en localhost sin despliegue. Lighthouse cubre íntegramente el requisito RNF-02.

3. Resultados de Lighthouse

Valores de la corrida mediana por combinación. *Scores* en 0–100; métricas de laboratorio en milisegundos (CLS es adimensional).

Página	Perfil	Perf	A11y	BP	SEO	FCP	LCP	TBT	CLS	SI
Inicio	mobile	100	100	96	100	618	751	0	0.000	618
Inicio	desktop	100	100	96	100	165	201	0	0.000	165
Login	mobile	100	100	96	100	620	751	0	0.000	620
Login	desktop	100	100	96	100	166	201	0	0.000	166

3.1 Veredicto contra el presupuesto RNF-02

Umbral (RNF-02 / metas del proyecto)	Observado	Resultado
FCP < 1 500 ms	165–620 ms (máx. 620)	Cumple
Performance ≥ 90	100 en las 4	Cumple
Accessibility ≥ 95	100 en las 4	Cumple

3.2 Oportunidades y diagnósticos

Lighthouse **no reportó oportunidades de rendimiento con ahorro estimado**: la superficie estática ya es óptima (TBT 0 ms, CLS 0, sin recursos que diferir). El único punto por debajo de 100 es **Best Practices = 96**, causado por `errors-in-console`: el navegador registra un error de red 404 al solicitar `/favicon.ico`, recurso que el sitio no declara. Es el hallazgo H1 de la tabla de correcciones.

3.3 Nota sobre la aplicación (SPA)

La aplicación autenticada es de *render en cliente* (CSR, ADR-002): sirve un documento mínimo y construye la interfaz en el navegador. Un *score* de documento de Lighthouse sobre ella no es comparable con el de una página estática —penaliza el arranque del *bundle* de forma que no refleja la experiencia real tras la hidratación— por lo que **no se reporta como métrica de documento** en este corte, en línea con RNF-02, que fija el presupuesto sobre la superficie pública. La SPA se gobierna por métricas de aplicación (tiempo a interactivo tras autenticación, latencia de *stream* de eventos C-3) que se instrumentan en la fase de observabilidad, no con Lighthouse.

4. Resultados de OWASP ZAP

Resumen por superficie. La cuenta de alertas es por *tipo*; entre paréntesis, el número de instancias.

Superficie	URLs auditadas	Alertas	Riesgo
Daemon (7431, autenticado)	11	0	—
Relay (8443)	6	2	1 Medio, 1 Bajo

4.1 Daemon — sin hallazgos

Sobre 11 endpoints autenticados (`/v1/health`, `/v1/sessions`, `/v1/approvals`, `/v1/rules`, `/v1/config/*`, `/v1/audit`) ZAP no levantó ninguna alerta. La captura directa de cabeceras sobre las respuestas 200 confirma el endurecimiento de la fase API; el relay, en contraste, no aplica todavía esta capa (origen de H3):

Cabecera de seguridad	Daemon	Relay
X-Content-Type-Options	nosniff	(ausente)
X-Frame-Options	DENY	(ausente)
Referrer-Policy	no-referrer	(ausente)
Cache-Control	no-store	(ausente)
Server (versión)	(ausente, sin fuga)	(ausente, sin fuga)
Access-Control-Allow-Origin	(no expuesto)	* (origen de H2)

4.2 Relay — 2 hallazgos

Alerta (ZAP)	Riesgo	Inst.	Clasificación
Cross-Domain Misconfiguration (id 10098, CWE-264, WASC-14)	Medio	5	Corregir (H2)
X-Content-Type-Options Header Missing (id 10021, CWE-693, WASC-15)	Bajo	1	Corregir (H3)

El hallazgo Medio corresponde a la cabecera Access-Control-Allow-Origin: * que el relay emite en todas sus respuestas; el Bajo, a la ausencia de nosniff en el relay (cabecera que el daemon sí incluye).

5. Análisis de hallazgos y correcciones

Cada hallazgo se clasifica en **corregir** (real, con fix concreto), **no corregir con justificación** (falso positivo o no aplicable por arquitectura) o **aceptado temporalmente** (real pero pospuesto, con el disparador que lo reactiva).

#	Hallazgo · análisis y decisión	Riesgo	Req.
H1	404 de /favicon.ico (Lighthouse, BP 96). El sitio Astro no declara favicon; el navegador lo pide de forma implícita y falla. → <i>Corregir (corte 2):</i> añadir <code>public/favicon.svg</code> y <code><link rel="icon"></code> en el layout base. Lleva Best Practices a 100.	Bajo	RNF-02
H2	CORS permisivo en el relay (Allow-Origin: *, ZAP Medio). Proviene de <code>CorsLayer::permissive()</code> , necesario en M2 para que la SPA (origen distinto) alcance el REST del relay entre orígenes. → <i>Corregir (corte 2):</i> restringir a una lista blanca configurable (<code>RELAY_SPA_ORIGINS</code>); permisivo solo bajo bandera de desarrollo.	Medio	RNF-09
H3	Falta X-Content-Type-Options en el relay (ZAP Bajo). El daemon ya fija <code>nosniff</code> ; el relay no aplica la misma capa de cabeceras. → <i>Corregir (corte 2):</i> añadir al relay la capa de seguridad del daemon (<code>nosniff</code> , <code>X-Frame-Options</code> , <code>Referrer-Policy</code> , <code>Cache-Control: no-store</code>).	Bajo	RNF-09
H4	Sin Content-Security-Policy en las respuestas de las APIs. La CSP protege documentos HTML frente a inyección de scripts; ambas superficies sirven <code>application/json</code> . La CSP de la SPA vive en su propio <code>index.html</code> . → <i>No corregir (justificado):</i> no aplica a una API JSON.	Info	—
H5	Sin HSTS / TLS en las APIs locales. El daemon acepta solo conexiones de <i>loopback</i> (RNF-04) y no usa TLS localmente; el relay corre HTTP en LAN sin despliegue público (ADR-009: el buzón en claro mantiene el relay dentro de LAN hasta M3). → <i>Aceptado temporalmente. Disparador:</i> el despliegue público con certificado del <i>hosting</i> lo convierte en corrección obligatoria.	Bajo	RNF-04
H6	/v1/health sin autenticación. Es una sonda de <i>liveness</i> ; devuelve solo estado y versión, ningún dato sensible. → <i>No corregir (justificado):</i> acceso anónimo deliberado por diseño.	Info	—
H7	El 400 del daemon repite el mensaje del parser JSON. Ante un cuerpo malformado devuelve el error de sintaxis (p. ej. <i>"key must be a string at line 1 column 2"</i>), sin traza de pila ni estado interno. → <i>No corregir (justificado):</i> ayuda al cliente y no filtra información sensible; el sobre de error es <code>ErrorEnvelope</code> estructurado.	Info	—

Corrección en caliente (sección 4.3). No se aplicó ninguna: la condición que la habilita —fugas de trazas de pila o cuerpos crudos del *upstream* en los errores— no se observó. Ambas APIs devuelven `{"error": {"code", "message"}}` sin filtración, en línea con el criterio de terminación de la fase API.

6. Plan hacia el corte 2

Correcciones comprometidas, cada una con su criterio de verificación objetivo (re-medición o re-escaneo que demuestre el delta):

- Favicon del sitio público (H1).** Verificación: re-correr Lighthouse en las 4 combinaciones; `errors-in-console` sin instancias y **Best Practices = 100**.
- Lista blanca de orígenes CORS en el relay (H2).** Verificación: re-escaneo ZAP del relay; la alerta *Cross-Domain Misconfiguration* (10098) desaparece con un origen no autorizado y persiste el acceso del origen configurado de la SPA.

3. **Capa de cabeceras de seguridad en el relay (H3).** Verificación: re-escaneo ZAP; la alerta *X-Content-Type-Options* (10021) desaparece; el *delta* de cabeceras daemon ↔ relay queda en cero.

Los hallazgos H4, H6 y H7 no requieren acción; H5 permanece aceptado hasta el despliegue público (M3), momento en que TLS/HSTS pasan a ser obligatorios.

7. Anexo — evidencia cruda e integridad

Los artefactos crudos que respaldan cada cifra viven en el repositorio del núcleo, bajo docs/audits/corte1/: los JSON+HTML de Lighthouse (lighthouse/) y de ZAP (zap/). A continuación, el hash SHA-256 de cada JSON (prefijo de 32 hex) para verificar que las cifras del reporte no se alteraron.

Artefacto (JSON crudo)	SHA-256 (prefijo)
lighthouse/landing-desktop-run1.report.json	cefc3d811a9fe2d09cef1e8470eddde6...
lighthouse/landing-desktop-run2.report.json	e256221aee4e6ca3821d828b5aa4eaa4...
lighthouse/landing-desktop-run3.report.json	b58f7a8925d3e34aa0fbc9618e2346fe...
lighthouse/landing-mobile-run1.report.json	50f921c4c7001c77748faaf38e42521f...
lighthouse/landing-mobile-run2.report.json	3decbc4c18a30f6c6f7fdd523753aeb2...
lighthouse/landing-mobile-run3.report.json	3ae254a34f79af4b954fd65baa4f71c6...
lighthouse/login-desktop-run1.report.json	b9cf94a76f9a1fdbcdec10426059275...
lighthouse/login-desktop-run2.report.json	4cc5ed56341339506dced32363516a1b...
lighthouse/login-desktop-run3.report.json	c91d680f7086535ca6c1c00e5bdb129c...
lighthouse/login-mobile-run1.report.json	bdaf32cae991cb6342b535d40f719783...
lighthouse/login-mobile-run2.report.json	7f0b3e0c714e95c2c1b2953e28dbfa63...
lighthouse/login-mobile-run3.report.json	4f88a51546d335d04388cc654f572e30...
zap/zap-daemon.json	5c1d06a319b357325bf270e6d59ad2a7...
zap/zap-relay.json	47178d2310408659e2b526be53b699b2...

Rutsubo · Reporte de Métricas y Auditoría de Seguridad · Corte 1 de 2 · Ramsés Alejandro Camas Nájera · MCIT-UPCh · julio 2026. Toda métrica proviene de una ejecución real de esta sesión; los artefactos crudos y sus hashes acompañan este documento.